J&J; ACELERAÇÃO CYBERSECURITY

MODELO DE RESPONSABILIDADE COMPARTILHADA NA PRÁTICA

Como as empresas distribuem responsabilidades, operam controles e respondem a incidentes em IaaS, PaaS e SaaS

Material didático do aluno

Computação em Nuvem | Segurança corporativa | Estudos de situações-problema

1. Objetivos de aprendizagem

Ao concluir a leitura, o estudante deverá ser capaz de: (a) identificar quem executa e quem supervisiona cada controle de segurança; (b) diferenciar responsabilidades em IaaS, PaaS e SaaS; (c) interpretar falhas reais ou plausíveis de configuração; (d) propor ações de prevenção, detecção, resposta e recuperação; e (e) reconhecer a importância de contratos, evidências e governança.

2. Como o modelo aparece na rotina das empresas

A organização não transfere toda a segurança ao contratar nuvem. O provedor protege os componentes sob sua gestão; o cliente continua responsável por dados, identidades, configurações e pelo uso seguro dos serviços, em extensão que varia conforme o produto contratado. Em ambientes reais, algumas atividades dependem de ambos: por exemplo, o provedor oferece mecanismos de log e criptografia, enquanto a empresa precisa habilitá-los, configurá-los e monitorá-los quando aplicável.

A pergunta operacional não é apenas “de quem é a culpa?”, mas “quem deve executar, aprovar, monitorar e comprovar cada controle?”. A resposta depende da arquitetura, dos contratos e da documentação específica do serviço.

3. Quem participa das decisões

Área / papel	Responsabilidade típica na prática
TI / Cloud Operations	Configurar contas, redes, recursos, backups, inventário e monitoramento operacional.
Segurança da Informação	Definir requisitos, acompanhar riscos, monitorar alertas, investigar incidentes e avaliar conformidade.
Desenvolvimento / DevSecOps	Corrigir vulnerabilidades do código, proteger segredos, aplicar testes e configurar pipelines.
Gestor do sistema / negócio	Aprovar acessos, classificar dados, priorizar continuidade e validar riscos residuais.
Jurídico / Privacidade	Avaliar contratos, requisitos legais, tratamento de dados e notificações aplicáveis.
Provedor de nuvem	Operar e proteger a infraestrutura e os componentes assumidos no serviço contratado.

4. Como a divisão muda em IaaS, PaaS e SaaS

Camada	IaaS	PaaS	SaaS
Instalações, hardware, infraestrutura física	Provedor	Provedor	Provedor
Sistema operacional do servidor	Cliente, em geral	Provedor, em geral	Provedor

Camada	IaaS	PaaS	SaaS
Runtime / plataforma gerenciada	Cliente, em geral	Provedor, em geral	Provedor
Código da aplicação	Cliente	Cliente	Provedor, em geral
Usuários, permissões e dados	Cliente, com controles do provedor	Cliente, com controles do provedor	Cliente, com controles do provedor
Configuração de segurança do serviço	Cliente conforme opções disponíveis	Cliente conforme opções disponíveis	Cliente conforme opções disponíveis

Atenção: a tabela é uma simplificação didática. Serviços gerenciados têm particularidades: em determinados produtos, atualizações, backups, chaves ou proteção de rede podem ser responsabilidades compartilhadas ou opcionais. Sempre consulte a matriz de responsabilidades do serviço específico.

5. Rotina operacional: da contratação ao monitoramento

1. Classificar o serviço: identificar se a solução é IaaS, PaaS, SaaS ou uma combinação e quais componentes são gerenciados pelo fornecedor.

2. Mapear dados e riscos: identificar informações sensíveis, requisitos de disponibilidade, regiões de armazenamento e necessidades de recuperação.

3. Definir responsáveis: documentar o responsável por configuração, aprovação, execução e verificação de cada controle.

4. Implantar com padrões seguros: aplicar MFA, menor privilégio, criptografia, segmentação, logging e configuração segura conforme o serviço.

5. Operar e auditar: monitorar eventos, revisar permissões, testar restauração, corrigir desvios e guardar evidências.

6. Responder e aprender: isolar impactos, preservar registros, revogar credenciais, restaurar serviços e atualizar processos após incidentes.

6. Situação-problema 1 — Armazenamento de arquivos exposto

Cenário: uma empresa de comércio eletrônico armazena notas fiscais e dados de clientes em um serviço de armazenamento de objetos. Durante uma mudança de configuração, um contêiner/bucket fica acessível publicamente. Um pesquisador informa que arquivos podem ser baixados sem autenticação.

Onde houve falha: o serviço de armazenamento é operado pelo provedor, mas as permissões de acesso aos objetos foram configuradas incorretamente pela organização. O provedor pode disponibilizar bloqueios de acesso público e alertas; cabe ao cliente aplicá-los conforme a arquitetura.

Consequências possíveis: exposição de dados, fraude, danos reputacionais e obrigações de resposta relacionadas à privacidade.

Resposta recomendada: restringir imediatamente o acesso; preservar logs e evidências; identificar quais arquivos e períodos foram afetados; avaliar eventual acesso indevido; comunicar áreas responsáveis; revisar políticas e implementar verificações automáticas de exposição.

Prevenção: bloqueio padrão de acesso público, políticas como código, revisões de mudança, alertas de configuração e classificação de dados.

7. Situação-problema 2 — Máquina virtual sem atualizações

Cenário: uma equipe hospeda um sistema legado em uma máquina virtual IaaS. A aplicação funciona, mas o sistema operacional está sem atualizações de segurança. Uma vulnerabilidade conhecida é explorada e o serviço fica indisponível.

Responsabilidade: o provedor mantém a infraestrutura física e o hipervisor sob sua gestão; a empresa normalmente mantém e atualiza o sistema operacional convidado, as aplicações e suas configurações na VM.

Resposta: isolar a instância afetada, preservar evidências, reconstruir a partir de imagem confiável, corrigir a vulnerabilidade, rotacionar credenciais potencialmente comprometidas e validar restauração.

Prevenção: inventário de VMs, política de patching, varredura de vulnerabilidades autorizada, imagens padronizadas e janelas de manutenção.

8. Situação-problema 3 — Aplicação PaaS com segredo no código

Cenário: uma startup utiliza uma plataforma PaaS para hospedar sua API. O provedor atualiza o ambiente de execução, mas um desenvolvedor publica uma chave de banco de dados no repositório de código. A chave é utilizada por terceiros.

Responsabilidade: a gestão do runtime não elimina a obrigação do cliente de proteger código, credenciais, identidades de serviço e permissões. A equipe deve revogar o segredo comprometido, revisar acessos e usar um cofre de segredos ou mecanismo equivalente.

Prevenção: revisão de código, detecção de segredos, identidades de workload quando disponíveis, permissões mínimas e rotação periódica baseada em risco.

9. Situação-problema 4 — SaaS e conta administrativa comprometida

Cenário: uma empresa usa uma plataforma SaaS de colaboração. Um administrador reutiliza senha e não habilita MFA. Um atacante obtém acesso à conta e altera regras de compartilhamento de documentos.

Responsabilidade: o fornecedor protege a infraestrutura e o software SaaS, enquanto a organização administra usuários, privilégios, políticas de compartilhamento e opções de autenticação disponíveis.

Resposta: bloquear sessões, redefinir credenciais, revogar tokens quando possível, analisar logs, revisar alterações e compartilhamentos, recuperar configurações e habilitar MFA forte.

Prevenção: SSO com MFA, contas administrativas separadas, acesso condicional, revisões de acesso e alertas para mudanças críticas.

10. Situação-problema 5 — Backup configurado, recuperação não testada

Cenário: uma clínica utiliza banco de dados gerenciado e acredita que o provedor garante a recuperação integral. Após exclusão acidental de registros, descobre que a retenção configurada era insuficiente e que nunca houve teste de restauração.

Responsabilidade: o provedor oferece recursos de backup conforme o produto; o cliente deve definir RPO (perda de dados tolerável), RTO (tempo de recuperação desejado), retenção e testes de restauração, respeitando os limites do serviço contratado.

Resposta: verificar pontos de recuperação disponíveis, recuperar dados de forma controlada, medir perdas, documentar causa e ajustar política de continuidade.

Prevenção: backup automatizado, cópias protegidas contra exclusão quando apropriado, simulações de desastre e responsáveis definidos.

11. Situação-problema 6 — Permissões excessivas entre contas e ambientes

Cenário: um pipeline de CI/CD utiliza credenciais permanentes com permissão administrativa em produção. A credencial é exposta em um log de execução. Um terceiro passa a alterar recursos.

Responsabilidade: a empresa deve configurar IAM e seus pipelines; o provedor fornece mecanismos de identidade, permissões e auditoria.

Resposta: revogar a credencial, avaliar ações realizadas, reverter alterações não autorizadas e substituir credenciais estáticas por autenticação federada ou temporária quando suportada.

Prevenção: menor privilégio, segregação de ambientes, revisão de papéis, autenticação de workload e proteção de logs.

12. Situação-problema 7 — Indisponibilidade do provedor

Cenário: um serviço crítico fica indisponível durante falha regional do provedor. A empresa tinha contratado alta disponibilidade em uma única zona, mas não desenhou redundância compatível com seu requisito de continuidade.

Responsabilidade: o provedor responde pela operação de seus serviços e pelos compromissos contratuais; a empresa deve projetar a resiliência de sua aplicação, avaliar dependências e escolher a arquitetura adequada ao risco.

Resposta: acionar plano de continuidade, informar usuários, acompanhar status oficial, executar failover se existir e avaliar impactos após a recuperação.

Prevenção: análise de SLA, testes de contingência, arquitetura resiliente e avaliação de dependências de terceiros.

13. Matriz de decisão para a empresa

Controle / pergunta	Responsável primário típico	Evidência esperada
MFA para administradores	Cliente	Política de identidade, relatório de adesão
Atualização do SO em VM IaaS	Cliente	Inventário e registros de patch
Segurança física do datacenter	Provedor	Relatórios e certificações contratuais
Políticas de bucket e compartilhamento	Cliente	Configurações e alertas
Proteção da plataforma gerenciada	Provedor	Documentação do serviço e compromissos
Rotação de chaves da aplicação	Cliente	Histórico de rotação e auditoria
Teste de recuperação dos dados	Cliente	Registro de teste e resultados
Correção de código vulnerável	Cliente	Pull requests, testes e versões

14. Como documentar um incidente: exemplo de registro corporativo

ID: INC-2026-014 | Serviço: armazenamento de objetos | Severidade: alta (provisória).

Fato observado: objeto acessível sem autenticação. Evidência: configuração do recurso, alerta do serviço e eventos de acesso. Hipótese: mudança indevida em política de acesso. Impacto: exposição potencial de documentos. Responsável por ação: equipe Cloud Operations. Apoio: Segurança, Privacidade e fornecedor, conforme necessário. Ação imediata: restringir acesso e preservar evidências. Correção permanente: política preventiva e validação automatizada. Verificação: teste autorizado de acesso e monitoramento posterior.

Esse formato ajuda a separar fatos confirmados, hipóteses, ações e responsáveis. Uma falha no cliente não exclui a necessidade de acionar o provedor quando houver suporte, evidências ou falha em serviço sob sua gestão.

15. Perguntas para análise dos casos

1. Em qual camada ocorreu o problema e qual serviço estava sendo utilizado?

2. Quais controles eram oferecidos pelo provedor e quais precisavam ser configurados pelo cliente?

3. Que evidências permitiriam confirmar o incidente sem extrapolar os fatos?

4. Quais seriam as primeiras medidas de contenção e recuperação?

5. Como distribuir responsabilidades entre TI, Segurança, Desenvolvimento, Negócio e fornecedor?

6. Que mudança de processo evitaria a repetição do problema?

16. Checklist de governança para organizações

☐ Inventário de serviços e responsáveis atualizado.

☐ Matriz de responsabilidade específica por serviço e contrato.

☐ Políticas de IAM, MFA e menor privilégio implantadas.

☐ Configurações de segurança verificadas continuamente.

☐ Dados classificados, criptografia e retenção definidas.

☐ Registros de auditoria habilitados e analisados.

☐ Gestão de vulnerabilidades, segredos e mudanças documentada.

☐ Backups e restaurações testados conforme RPO/RTO.

☐ Plano de resposta a incidentes e contatos do provedor disponíveis.

☐ Revisões periódicas de riscos e de responsabilidades.

17. Síntese

Na prática, responsabilidade compartilhada é uma disciplina de governança: contratos esclarecem obrigações, arquitetura define os limites técnicos, equipes executam controles e evidências demonstram que os riscos são gerenciados. O cliente não pode presumir que a contratação de nuvem substitui segurança interna; tampouco deve assumir que todos os componentes são seus. A divisão exata precisa ser confirmada para cada serviço.

18. Referências para aprofundamento

NIST. The NIST Definition of Cloud Computing (SP 800-145). https://doi.org/10.6028/NIST.SP.800-145

AWS. Shared Responsibility Model. https://aws.amazon.com/compliance/shared-responsibility-model/

Microsoft Learn. Shared responsibility in the cloud. https://learn.microsoft.com/azure/security/fundamentals/shared-responsibility

Google Cloud. Shared responsibility and shared fate. https://cloud.google.com/architecture/framework/security/shared-responsibility-shared-fate

NIST. Cybersecurity Framework (CSF) 2.0. https://www.nist.gov/cyberframework